## Übungen zu Aufgaben in Kapitel 2 (Grundsätze im Datenschutz)

1. **Welche zwei Aussagen definieren eine betroffene Person?**

   - ☐ Die Nationalität
   - ☐ Eine identifizierte oder identifizierbare natürliche Person
   - ☐ Einen Beschäftigten der indirekt bestimmbar ist.
   - ☐ Eine identifizierte oder identifizierbare juristische Person
   - ☐ Eine durch eine Rechtsverletzung benachteiligte anonyme Person

2. **Welche Grundsätze gem. DSGVO gelten für die Verarbeitung von personenbezogenen Daten?**

   - ☐ Transparenz
   - ☐ Zweckbindung
   - ☐ Kopplungsverbot
   - ☐ Datenminimierung
   - ☐ Speicherbegrenzung
   - ☐ Rechenschaftspflicht
   - ☐ Informationelle Selbstbestimmung
   - ☐ Freiwilligkeit des Betroffenen

3. **Wie kannst du das Prinzip der Datenminimierung erfüllen?**

   - ☐ So wenig Daten wie möglich erheben
   - ☐ Der vorgegebene Speicherplatz für die Daten sollte nicht überschritten werden
   - ☐ Nur die Daten erheben, die für die Erfüllung des Zweckes erforderlich sind
   - ☐ Doppelte Datenerhebung sollte vermieden werden
   - ☐ Alle Daten sollten nur noch abgekürzt gespeichert werden

4. **Was versteht man unter dem juristischen Begriff „Verbot mit Erlaubnisvorbehalt“? (pbD = personenbezogene Daten)**

   - ☐ Die Verarbeitung von pbD ist grundsätzlich verboten. Die Gesetze der DSGVO und des BDSG machen von dieser Regel ein paar Ausnahmen, die als Erlaubnistatbestände aufgezählt werden.
   - ☐ Damit ist gemeint, dass es verboten ist, gegen den Datenschutz zu verstoßen. Nur die Aufsichtsbehörde darf eine Genehmigung zur Datenverarbeitung von pbD erteilen.
   - ☐ Die Verarbeitung von nicht-öffentlichen Stellen wird damit eingeschränkt. Juristische Personen sind davon ausgeschlossen.
   - ☐ Die Erlaubnistatbestände sind im Art.6 der DSGVO aufgeführt. Wenn keiner dieser Tatbestände anwendbar ist, dann darf ich personenbezogene Daten nicht verarbeiten.

5. **Was sind die Bedingungen einer rechtskonformen Einwilligung nach der DSGVO?**

   - ☐ Zweck der Verarbeitung muss angegeben sein
   - ☐ Nachweisbarkeit sollte gegeben sein
   - ☐ Nennung des Speicherortes
   - ☐ Widerrufsrecht muss eingeräumt sein
   - ☐ Übersichtlicher Text, max. 1 Din A4 Seite

6. **Deine Firma will den Besuchern der Unternehmenswebsite anbieten den neuen Newsletter online zu abonnieren. Was bedeutet in dem Zusammenhang das Double-Opt-In Verfahren?**

   - ☐ Der User muss sowohl über den Zweck als auch die Rechtsgrundlage der Erhebung der Daten informiert werden.
   - ☐ Der User muss schriftlich und elektronisch in die Verarbeitung seiner Daten einwilligen.
   - ☐ Die Daten müssen an zwei Orten gespeichert sein, um bei einem Datenverlust immer auf eine Kopie zurückgreifen zu können.
   - ☐ Der User muss eine elektronische Einwilligung nochmals per E-Mail bestätigen, z.B. durch Anklicken eines Links.

7. **Was ist bei der Einwilligung von Kindern, im Sinne des Art. 8 DSGVO zu beachten?**

   - ☐ Kinder ab 16 Jahren dürfen selbst einwilligen, wenn sie einen Dienst der Informationsgesellschaft nutzen, der sich direkt an Kinder und Jugendliche wendet.
   - ☐ Kinder unter 16 Jahren benötigen die Einwilligung oder Zustimmung der Erziehungsberechtigten.
   - ☐ Eine rechtswirksame Einwilligung kann nur ab dem 18 Lebensjahr abgegeben werden.
   - ☐ Die Einwilligung von Kindern muss mit Grafiken verständlich gemacht werden und darf keinen Text enthalten.
   - ☐ Die Einwilligung von Kindern muss mit einem Double-Opt-In Verfahren verifiziert werden.

8. **Welche Rechte gehören zu den unabdingbaren Rechten der Betroffenen?**

   - ☐ Recht auf Einschränkung / Sperrung
   - ☐ Recht auf Auskunft
   - ☐ Recht auf Berichtigung
   - ☐ Recht auf Treu und Glaube
   - ☐ Recht auf Löschung
   - ☐ Recht auf Beschwerde
   - ☐ Recht auf Datenminimierung

9. **Du erhältst einen Anruf eines vermeintlichen Kunden, der sein Recht auf Auskunft wahrnehmen möchte. Deiner Firma liegen allerdings keine Daten dieser Person vor. Muss der Verantwortliche auf diese Anfrage reagieren?**

   - ☐ Nein, der Verantwortliche muss nicht reagieren, da keine Verarbeitung stattgefunden hat
   - ☐ Der Verantwortliche muss dem Recht auf Auskunft nur folgen, wenn sein Unternehmen besondere personenbezogene Daten verarbeiten würde.
   - ☐ Ja, da die betroffene Person zunächst das Recht hätte zu erfahren, ob persönliche Daten verarbeitet wurden.
   - ☐ Vor einer solchen Auskunft (auch bei Negativauskunft), muss zunächst die Identität geprüft werden.

**10. Was ist mit dem Recht auf Widerspruch gemeint?**

- ☐ Widerspruch gegen die erteilte Einwilligung
- ☐ Widerspruch gegen die Datenverarbeitung
- ☐ Widerspruch gegen die nicht erfolgte Löschen wegen anderer Aufbewahrungspflichten des Unternehmens
- ☐ Widerspruch gilt nur in Bezug auf die Verarbeitung der personenbezogenen Daten, eine erteilte Einwilligung wird widerrufen nicht widersprochen

**11. Unter welchen Voraussetzungen muss der Verantwortliche personenbezogene Daten unverzüglich löschen?**

- ☐ Wenn der Betroffene seine Einwilligung widerrufen hat
- ☐ Wenn der DSB es verlangt
- ☐ Wenn der Betroffene der Verarbeitung seiner personenbezogenen Daten rechtsgültig widerspricht.
- ☐ Wenn der Zweck der Datenverarbeitung erfüllt ist und keine Aufbewahrungspflicht besteht.
- ☐ Wenn keine Rechtsgrundlage der DSGVO oder des BDSG zur Verarbeitung der Daten vorliegt.
- ☐ Nachdem ein Betroffener von seinem Auskunftsrecht Gebrauch gemacht hat.

**12. Über welche Inhalte müssen Betroffene zum Zeitpunkt einer Datenerhebung grundsätzlich informiert werden?**

- ☐ Die Rechtsgrundlage(n) für die Verarbeitung
- ☐ Name und Kontaktdaten des DSB (wenn vorhanden)
- ☐ Name und Kontaktdaten der verarbeitenden Stelle / des Verantwortlichen
- ☐ Name und Kontaktdaten der zuständigen Aufsichtsbehörde
- ☐ Zweck der Datenerhebung und Dauer der Speicherung
- ☐ Geplante Übermittlung in Drittländer
- ☐ Die wichtigsten Begriffsbestimmungen zum Datenschutz

**13. Eine Mitarbeiterin aus deiner Firma meldet eine Datenschutzverletzung an deinen Geschäftsführer. Welche Schritte sind zu ergreifen?**

- ☐ Der DSB muss sofort informiert werden
- ☐ Im Falle eines Risikos für die Rechte und Freiheiten von Betroffenen, muss die Datenpanne der Aufsichtsbehörde gemeldet werden (durch den Verantwortlichen)
- ☐ In jedem Fall müssen die Betroffenen über die Datenschutzverletzung und deren mögliche Folgen informiert werden
- ☐ Nur bei einem hohen Risiko für die Rechte und Freiheiten von Betroffenen müssen diese über die Datenschutzverletzung und deren mögliche Folgen informiert werden
- ☐ Die Datenpanne muss dokumentiert werden

**14. Welche der folgenden Vorfälle stellt eine Datenpanne gem. DSGVO dar?**

- ☐ Der PC-Arbeitsplatz in der Personalabteilung hat keine automatische Bildschirmsperre
- ☐ Verlust eines unverschlüsselten USB-Sticks mit personenbezogenen Daten
- ☐ Einbruch im Unternehmen und Diebstahl des Servers
- ☐ Das Verzeichnis der Verarbeitungstätigkeiten ist nicht vollständig und muss aktualisiert werden
- ☐ Ein Sachbearbeiter der Buchhaltungsabteilung hat versehentlich zwei Gehaltsmitteilungen vertauscht

**15. Welche Informationen muss die Meldung einer Datenschutzverletzung an die Aufsichtsbehörde mindestens enthalten?**

- ☐ Name und Kontaktdaten des DSB
- ☐ Beschreibung der Datenschutzverletzung
- ☐ Beschreibung der wahrscheinlichen Folgen
- ☐ Kategorie und ungefähre Anzahl der Datensätze
- ☐ Name und Kontaktdaten der Betroffenen

16. **Die Übermittlung von Daten in Drittländer ist nach der DSGVO zulässig, wenn...**

- ☐ die betroffene Person in die Übermittlung gem. Art. 49 (1) lit. a DSGVO ausdrücklich eingewilligt hat
- ☐ das Land ein angemessenes Schutzniveau hat und dies mittels Angemessenheitsbeschluss nach Art. 45 nachgewiesen wurde
- ☐ das Unternehmen ein Verzeichnis der Verarbeitungstätigkeiten der Aufsichtsbehörde vorgelegt hat
- ☐ eine Datenschutz-Folgenabschätzung gem. Art. 35 DSGVO stattgefunden hat
- ☐ der Verantwortliche geeignete Garantien vorgesehen hat, z.B. durch Standardvertragsklauseln

17. **Was ist im Sinne der DSGVO unter einem Drittland zu verstehen?**

- ☐ Ein Land, in dem die DSGVO zur Anwendung kommt
- ☐ Ein Land innerhalb der Europäischen Union
- ☐ Ein Land außerhalb der Europäischen Union
- ☐ Ein Land für das ein angemessenes Datenschutzniveau vorliegt
- ☐ Das Empfängerland nach einer Übermittlung an einen Dritten

18. **Dein Unternehmen möchte personenbezogene Daten an andere Unternehmen übermitteln. Welche Voraussetzungen müssen dazu erfüllt werden?**

- ☐ Es muss mindestens eine Rechtsgrundlage nach DSGVO oder BDSG erfüllt sein, um Daten zu verarbeiten
- ☐ Zuvor muss eine Datenschutz-Folgenabschätzung durchgeführt werden
- ☐ Es müssen keine Voraussetzungen berücksichtigt werden, da die Übermittlung keine Datenverarbeitung ist
- ☐ Wenn die Übermittlung eine Auftragsverarbeitung darstellt, muss ein Auftragsverarbeitungsvertrag geschlossen worden sein
- ☐ Bei der Übermittlung in ein Drittland müssen zusätzliche Regelungen nach Art. 44 ff DSGVO berücksichtigt werden, wie Angemessenheitsbeschlüsse oder geeignete Garantien, die ein ähnliches Datenschutzniveau wie das der EU garantieren

**19. In welchen der folgenden Bereiche ist Videoüberwachung grundsätzlich verboten?**

- ☐ Umkleidekabinen des Unternehmens
- ☐ In der Kantine
- ☐ Ruheraum der Mitarbeiter in einer Arztpraxis
- ☐ Flure und IT-Abteilung einer Behörde
- ☐ Vorräume einer Toilette eines Vereines
- ☐ Duschräume
- ☐ Toilettenräume
- ☐ Öffentlicher Parkplatz

**20. Was soll bei der Verpflichtung der Mitarbeiter auf die Vertraulichkeit beachtet werden?**

- ☐ Die Mitarbeiter sollen verstehen, was das Ziel dieser Verpflichtung ist
- ☐ Der Fokus muss auf den Bußgeldvorschriften liegen und es wird mit Abmahnungen gedroht
- ☐ Im Rahmen der Aufklärung müssen die Mitarbeiter mit sämtlichen Regelungen der DSGVO, dem BDSG, DDG, TDDDG und dem TMK vertraut gemacht werden und einen Wissenstest absolvieren
- ☐ Die Verpflichtung auf die Vertraulichkeit sollte erst erfolgen, wenn die Mitarbeiter ausreichend in den Umgang mit personenbezogenen Daten eingewiesen wurden.

**21. Mit welchen Maßnahmen können die Verantwortlichen eine bessere Akzeptanz des Datenschutzes herstellen?**

- ☐ Die Geschäftsführung sollte als Vorbild vorangehen
- ☐ Mitarbeiter frühzeitig und umfassend informieren
- ☐ Mitarbeiterschulungen interessant und für die tatsächliche Verarbeitung gestalten, damit der Sinn für den Datenschutz klar zu erkennen ist
- ☐ Mitarbeiter regelmäßig mit Bußgeldern und Sanktionen drohen
- ☐ Die Kenntnisse der Mitarbeiter zum Datenschutz monatlich prüfen

**22. Dein Unternehmen möchte auf der firmeneigenen Website ein Analyse-Tool verwenden, welches das Nutzerverhalten der Website-Besucher auswertet. Welche Regelungen sind dazu zu beachten?**

- ☐ Es muss eine Datenschutz-Folgenabschätzung durchgeführt werden
- ☐ Die Datenschutzerklärung der Website muss den Besucher umfassend über die Verwendung der Cookies gem. DSGVO und TDDDG informieren
- ☐ Es sind keine besonderen Regelungen zu beachten, da es sich bei Cookies immer um technisch notwendige Maßnahmen handelt
- ☐ Die Besucher der Website müssen zuvor über ein Cookie-Banner einwilligen [gem. § 25 (1) TDDDG]
- ☐ Der Verantwortliche muss ggf. einen Vertrag zur Auftragsverarbeitung mit dem Anbieter des Analyse-Tools schließen

**23. Welches sind die Schutzziele in der Informationssicherheit?**

- ☐ Verfügbarkeit
- ☐ Verschlüsselung
- ☐ Authentizität
- ☐ Pseudonymisierung
- ☐ Belastbarkeit
- ☐ Vertraulichkeit
- ☐ Datenminimierung
- ☐ Nichtverkettung
- ☐ Transparenz
- ☐ Intervenierbarkeit
- ☐ Wiederherstellung
- ☐ Wirksamkeit
- ☐ Integrität
- ☐ Nichtabstreitbarkeit

**24. Welches sind die Schutzziele im Datenschutz gem. DSGVO?**

- ☐ Verfügbarkeit
- ☐ Verschlüsselung
- ☐ Authentizität
- ☐ Pseudonymisierung
- ☐ Belastbarkeit
- ☐ Vertraulichkeit
- ☐ Datenminimierung
- ☐ Nichtverkettung
- ☐ Transparenz
- ☐ Intervenierbarkeit
- ☐ Wiederherstellung
- ☐ Wirksamkeit
- ☐ Integrität
- ☐ Nichtabstreitbarkeit

**25. Welches sind die Schutzziele nach SDM (Standard Datenschutz Model)?**

- ☐ Verfügbarkeit
- ☐ Verschlüsselung
- ☐ Authentizität
- ☐ Pseudonymisierung
- ☐ Belastbarkeit
- ☐ Vertraulichkeit
- ☐ Datenminimierung
- ☐ Nichtverkettung
- ☐ Transparenz
- ☐ Intervenierbarkeit
- ☐ Wiederherstellung
- ☐ Wirksamkeit
- ☐ Integrität
- ☐ Nichtabstreitbarkeit

**26. Dein Unternehmen möchte deine personenbezogenen Daten an andere Empfänger übermitteln. Welches Gesetz(e) regeln und ermöglichen das?**

- ☐ Ausschließlich die DSGVO
- ☐ DSGVO in Verbindung mit dem BDSG
- ☐ Ausschließlich das BDSG bei Beschäftigten
- ☐ Das BGB
- ☐ Keine der o.a. Antworten ist richtig

**27. Welche Personen müssen vor einer Datenverarbeitung ihrer personenbezogenen Daten informiert werden?**

- ☐ Nutzer der Website
- ☐ Interessenten bei Anfragen über die Kontaktseite der Internetseite
- ☐ Beschäftigte
- ☐ Bewerber
- ☐ Praktikanten
- ☐ Geschäftspartner und Lieferanten
- ☐ Behörden
- ☐ Kunden

**28. Welche groben Inhalte sollte eine Information zu Datenschutz enthalten?**

- ☐ Die Kontaktdaten des Verantwortlichen und des DSBs (wenn benannt)
- ☐ Den Zweck der Datenverarbeitung
- ☐ Die Empfänger der Daten
- ☐ Eine beabsichtigte Übermittlung in Drittländer
- ☐ Die Webadresse des Unternehmens
- ☐ Die Anzahl der Beschäftigten und die Art des Unternehmens
- ☐ Die Dauer der Speicherung der Daten
- ☐ Eine Auflistung der Betroffenenrechte
- ☐ Hinweise zum Beschwerde- und Widerrufsrecht
- ☐ Informationen in der Landessprache und mindestens auch in englischer Sprache verfasst sein

**29. Welchen Zweck erfüllen TOMs (techn.- organisatorische Maßnahmen)?**

- ☐ TOMs sind nach DSGVO vorgeschrieben und müssen nicht immer einen Zweck erfüllen
- ☐ TOMs erfüllen Anforderungen zu Schutzzielen der DSGVO
- ☐ TOMs erfüllen Anforderungen zu Schutzzielen der Informationssicherheit
- ☐ Organisatorische Maßnahmen können Richtlinien und Mitarbeiteranweisungen sein
- ☐ Technische Maßnahmen können z.B. durch Transponder Key Schließsysteme als Zutrittskontrolle umgesetzt werden, um einen berechtigten Zutritt zu gewährleisten
- ☐ TOMs sind nur in datenschutzrechtlichen Aspekten wirksam
- ☐ TOMs beziehen ausschließlich auf die Datensicherheit

**30. Welche Risikoansätze werden bei der Verarbeitung personenbezogener Daten nach DSGVO im Vergleich zur allgemeinen IT verfolgt?**

- ☐ Es gibt keinen Unterschied, da beide die gleiche Formel zur Berechnung des Risikoausmaßes verwenden.
- ☐ Der Datenschutz nach DSGVO betrachtet die qualitativen Risken, denen die Rechte und Freiheiten natürlicher Personen ausgesetzt sind. Diesen Risiken liegen keine direkt quantifizierbaren Werte zugrunde – sie müssen kategorisiert werden.
- ☐ Die allgemeine IT verfolgt einen quantifizierbaren Ansatz, bei dem die Schadenshöhe und die Eintrittswahrscheinlichkeit zum Einsatz kommen.

**31. Was versteht man im Datenschutz unter einer Schutzbedarfsanalyse?**

- ☐ Die Methode, wie alle Informationen im Unternehmen abgesichert werden müssen.
- ☐ Bildung von Schutzbedarfskategorien aus einer Risikoanalyse über personenbezogene Daten.
- ☐ Die Beschreibung welche Technisch-Organisatorische Maßnahme zu welchem Risiko passt.

**32. Welche der folgenden Daten zählen nicht zu den „Daten besonderer Kategorie“ nach Art. 9 DSGVO wie z.B. Gesundheitsdaten?**

- ☐ Bankdaten
- ☐ Biometrische Daten
- ☐ Religiöse Überzeugung
- ☐ Polizeiliches Führungszeugnis

**33. Welche der folgenden Rechte sind keine Betroffenenrechte gemäß DSGVO?**

- ☐ Recht auf Berichtigung
- ☐ Recht auf Verschlüsselung
- ☐ Recht auf Einschränkung der Verarbeitung
- ☐ Recht auf Anonymisierung

**34. Welche beiden der folgenden Aussagen sind falsch? Das Auskunftsrecht nach DSGVO…**

- ☐ … gilt nur gegenüber Behörden, nicht gegenüber Privatunternehmen.
- ☐ … wird durch die Aufsichtsbehörde ausgeübt.
- ☐ … schließt das Recht auf eine Kopie der Daten ein.
- ☐ … kann bei exzessiver Nutzung verweigert werden.

**35. Die besonderen Kategorien des Art. 9 DSGVO wie z.B. biometrische Daten bezeichnen besonders schützenswerte personenbezogene Daten und untersagen grundsätzlich die Verarbeitung der bezeichneten Daten/ Informationen.**
**Es gibt aber Ausnahmen. Welche Aussagen sind richtig?**

- ☐ Die Einwilligung der betroffenen Person liegt in rechtsgültiger Form vor.
- ☐ Die Datenverarbeitung dient dem berechtigten Interesse der Verantwortlichen Stelle.
- ☐ Die Verarbeitung ist aus arbeits- und sozialrechtlichen Gründen notwendig.
- ☐ Die Verarbeitung dient zur Vertragserfüllung und -anbahnung oder eines Arbeitsvertrages.

36. **Welches ist im normalen Geschäftsbereich die sicherste und stärkste Rechtsgrundlage für die Verarbeitung personenbezogener Daten?**

- ☐ Die Einwilligung, weil die von der betroffenen Person bewusst gegeben werden muss.
- ☐ Berechtigte Interessen, weil die am breitesten ausgelegt werden können.
- ☐ Ein Vertrag, der auf Anfrage der betroffenen Person zustande kommt.

37. **Gemäß dem Grundsatz der Datensparsamkeit dürfen nach DSGVO nur die für die Zweckerfüllung benötigten Daten erhoben und verarbeitet werden.**

**Als Fachinformatiker haben Sie die Aufgabe, für einen Online-Büchershop eine entsprechende Eingabemaske zu entwerfen.**

**Die Maske soll zusätzlich zum Namen, zu Kontakt- und Zahlungsdaten noch Daten zum Einkommen, Alter und Familienstand enthalten.**

**Wie muss die Eingabemaske konditioniert werden?**

- ☐ Alle Eingabefelder können als Pflichtfelder deklariert werden, da die Daten auch anderweitig verwendet werden können.
- ☐ Es müssen keine Pflichtfelder gekennzeichnet werden, damit die Kunden zum Ausfüllen aller Felder motiviert werden.
- ☐ Nur die für den Verkauf benötigten Daten dürfen als Pflichtfelder gekennzeichnet werden, die anderen müssen als optional erkennbar sein.